

ResolvX

Patch Management Policy

Topic-Specific Policy - Vulnerability Remediation & Patch Management

POL-010 · v1.0 · 2026 · Internal : Restricted

Document Information

Policy ID	POL-010
Version	1.0
Status	Active
Classification	Internal - Restricted
Owner	DevSecOps
Approver	CISO
Review Cycle	Annual, or upon material change to tooling or SLA
Next Review	Q3 2027
Frameworks	ISO 27001:2022 A8.8 · NIST CSF 2.0 ID.RA-01, DE.CM-09 · SOC 2 CC7.1

1. Purpose

This Patch Management Policy establishes how ResolvX identifies, prioritises, and remediates vulnerabilities across its codebase, cloud infrastructure, and corporate endpoints.

A disciplined, time-bound patching process keeps ResolvX's exposure to known vulnerabilities low and predictable, and gives clients, regulators, and auditors confidence that identified weaknesses are tracked to closure rather than left open indefinitely. This policy formalises the severity-based remediation SLAs that govern that process.

This policy satisfies ResolvX's obligations under ISO 27001:2022 A8.8 (Management of technical vulnerabilities) and supports the vulnerability management practices already in place through Snyk, AWS, and Jamf.

2. Scope

This policy applies to:

- Application source code and third-party dependencies (SAST/SCA, container, and infrastructure-as-code scanning via Snyk).
- Cloud infrastructure operating systems and managed services (AWS EC2, EKS, RDS).
- Corporate endpoints (Jamf-managed macOS devices).
- Third-party SaaS vulnerabilities are tracked through the vendor's own disclosure process and the Vendor Management Policy (POL-005), not through this policy directly.

3. Severity Definitions

Vulnerability severity follows CVSS v3.1 base scores, consistent with Snyk's native severity classification:

Severity	CVSS Range	Examples
Critical	9.0 – 10.0	Remote code execution, authentication bypass, actively exploited CVEs
High	7.0 – 8.9	Privilege escalation, significant data exposure, high confidence exploit path
Medium	4.0 – 6.9	Limited-impact information disclosure, requires specific conditions to exploit
Low	0.1 – 3.9	Minimal impact, theoretical or very low exploitability

4. Remediation SLA

Every in-scope system is remediated within the following timeframes, measured from the date a finding is detected:

Severity	Remediation SLA	Escalation (if breached)
Critical	7 days	Immediate escalation to VP Engineering and CISO; may trigger Incident Response Plan evaluation
High	30 days	Automatic Jira ticket creation on detection; escalation to VP Engineering at day 25 if unresolved
Medium	60 days	Included in monthly DevSecOps vulnerability review
Low	90 days, or next scheduled maintenance window	Tracked; no individual escalation required

Any finding that breaches its SLA is logged as a Corrective Action Plan item with a named owner and revised remediation date.

A finding is only considered closed once a follow-up scan confirms the vulnerability is no longer present. Closing the associated ticket without a verifying re-scan does not satisfy this policy.

5. Patch Management by System Type

System Type	Detection Method	Patching Owner	Deployment Path
Application code & dependencies	Snyk SAST / SCA / container scanning	DevSecOps	Pull request → CI/CD pipeline
Infrastructure-as-code	Snyk IaC scanning	DevSecOps / Head of Cloud Ops	Pull request → CI/CD pipeline
Cloud infrastructure (EC2, EKS)	AWS vulnerability tooling + Snyk	Head of Cloud Ops	Scheduled maintenance window
Managed database (RDS)	AWS-managed patching	Head of Cloud Ops	AWS-managed maintenance window
Corporate endpoints	Jamf compliance policies	IT Admin	Automated OS/application update enforcement

5.1 Testing & Rollback

Patches to production systems and production-facing application code are deployed through staging before reaching production, following the same environment-separation path as any other change. A patch is not exempt from testing simply because it addresses a security finding, an untested patch that causes an outage trades one incident for another.

- Application and infrastructure-as-code patches: validated in staging via the standard CI/CD pipeline before production deployment.
- Cloud infrastructure and managed service patches: applied in a scheduled maintenance window with a defined rollback plan (snapshot or version pinning) before the window opens.

- Endpoint patches: Jamf-managed deployment rings (a limited pilot group before fleet-wide rollout) are used for major OS version updates.

Every patch deployment has an identified rollback path before it is applied. Where no rollback path exists (e.g., an irreversible database migration bundled with a patch), Head of Cloud Ops and VP Engineering jointly approve deployment before it proceeds.

6. Vulnerability Scanning & Detection

6.1 Continuous Detection

- Snyk runs continuous SAST, SCA (dependency), container, and infrastructure-as-code scanning integrated into the CI/CD pipeline. New findings are surfaced automatically, not on a manual schedule.
- High and Critical findings generate an automatic ticket for tracking and SLA measurement.
- Jamf enforces macOS and application update compliance across corporate endpoints, with non-compliant devices flagged for follow-up by IT Admin.
- AWS infrastructure is scanned on a schedule aligned to the maintenance windows defined by Head of Cloud Ops.

6.2 Emergency Patching

A Critical-severity finding that is being actively exploited in the wild, or for which a working public exploit exists, is not subject to the standard 7-day Critical SLA in §4. It is remediated the same day it is confirmed, following this path:

- DevSecOps confirms active exploitation status and notifies the CISO and VP Engineering immediately.
- Standard staging validation in §5.1 is compressed to the minimum viable check, not skipped entirely, unless the CISO explicitly authorises a direct production patch.
- The CISO evaluates whether the finding also warrants activation of the Incident Response Plan, if there is any indication of exploitation against ResolvX systems specifically rather than a general public disclosure.
- A post-patch review is conducted within 5 business days, regardless of outcome, and logged as audit evidence.

6.3 End-of-Life Software

Software or infrastructure components approaching vendor end-of-life (EOL) are treated as a distinct risk from a normal patchable vulnerability, since no future patch will be issued once EOL is reached.

- DevSecOps and Head of Cloud Ops maintain awareness of EOL dates for components in active use, informed by Snyk's dependency and license reporting.
- A component within 6 months of its EOL date is flagged for a migration or upgrade plan, owned by the relevant system owner from §5.
- A component that reaches EOL without a completed migration is logged as a Corrective Action Plan item and escalated to VP Engineering; continued use requires a documented, CISO-approved risk acceptance.

7. Roles & Responsibilities

7.1 DevSecOps

- Owns this policy and the vulnerability management programme.
- Triage and assigns findings, tracks SLA compliance, and escalates breaches.
- Maintains the Snyk-to-Jira integration and reporting.

7.2 VP Engineering

- Ensures vulnerability remediation is prioritised within sprint planning.
- Receives escalation for Critical findings and any High finding approaching SLA breach.

7.3 Head of Cloud Ops

- Owns patching of cloud infrastructure and managed services (§5).

7.4 IT Admin

- Owns endpoint patch compliance through Jamf.

7.5 GRC Lead

- Tracks SLA-breaching findings as Corrective Action Plan items.
- Reviews vulnerability metrics as part of quarterly audit-readiness reporting.

8. Monitoring & Reporting

DevSecOps reviews vulnerability scan results, patch SLA compliance, and container scan reports on a monthly cadence. The primary metric tracked is Mean Time to Remediate (MTTR), measured separately by severity tier, against the SLA targets in §4. Any systemic SLA breach pattern, or a rising MTTR trend for any tier, is reported to the CISO and considered in the annual policy review.

9. Compliance and Enforcement

Failure to remediate a finding within its SLA without a documented risk acceptance is treated as a control deficiency and logged in the Corrective Action Plan. Temporary risk acceptance for a specific finding follows the tiered exception approval authority defined in POL-026 — a Critical or High-severity finding's exception requires CISO approval, consistent with POL-026 §4 — and is time-limited and logged in the Policy Exception Register.

10. Document Control

Policy ID	POL-010
Version	1.0
Status	Active
Classification	Internal - Restricted
Owner	DevSecOps
Approver	CISO
Review Cycle	Annual, or upon material change to tooling or SLA
Next Review	Q3 2027
Framework References	ISO/IEC 27001:2022 A8.8 · NIST CSF 2.0 ID.RA-01, DE.CM-09 · SOC 2 TSC CC7.1
Related Documents	POL-001 (Information Security Policy), POL-005 (Vendor Management Policy), POL-007 (Logging & Monitoring Policy), POL-026 (Policy Exception Governance Policy), Policy Exception Register

ResolvX GRC Program — Internal Use Only — v1.0 — 2026

Authorisation

Role	Name	Date
CEO		
CISO		
GRC Lead		